GLOBALTECH INC.

EXECUTIVE BRIEFING

Quantitative Phishing Risk Assessment & Security Investment Recommendations

DOCUMENT INFORMATION	DETAILS
Prepared for	Board of Directors, CISO and CFO
Prepared by	Lead GRC Analyst
Date	31 October 2026
Classification	Internal – Training and Risk Assessment Exercise
Subject	Phishing Risk Assessment and $652.5 Million Modelled Exposure
Currency	United States Dollars (USD)

---

1. EXECUTIVE OVERVIEW

GlobalTech Inc. conducted three phishing simulations during the previous quarter to evaluate employee susceptibility to phishing attacks and identify potential weaknesses in organisational security controls. The campaigns targeted general employees, executives and assistants through simulated HR bonus notifications, IT password-reset requests and urgent CEO document-review messages.

The assessment recorded **430 emails sent, 354 emails opened, 257 link clicks, 105 credential submissions and 38 additional data-entry events**. The combined credential-submission rate was **24.42%**, highlighting a significant human-related cybersecurity concern.

Campaign B, *IT System Password Reset*, emerged as the highest-risk campaign, recording a 30% credential-submission rate. This was followed by Campaign A at 18% and Campaign C at 15%.

Applying Campaign B's credential-submission rate to the organisation's 2,000 employees produces an estimated 600 potential credential submissions. Using the supplied 25%

conditional probability of a major breach produces 150 expected breach-equivalent outcomes.

At the assumed cost of $4.35 million per breach, this results in a **modelled financial exposure of $652.5 million**.

This is a scenario-based financial estimate rather than a verified annual loss forecast. The assumptions connecting compromised accounts to separate breach events and annual occurrence frequency require further validation before this figure can be used for actual organisational budgeting.

2. EXECUTIVE RISK DASHBOARD

The following indicators summarise the most significant findings from the assessment.

KEY RISK INDICATOR	ASSESSMENT RESULT
Total phishing emails sent	430
Combined credential-submission rate	**24.42%**
Highest campaign credential-submission rate	**30%**
Projected credential submissions	600 employees
Expected breach-equivalent outcomes	150
Campaign B modelled financial exposure	**$652.5 million**
Highest stand-alone control ROI	**724,175% – MFA**

3. PRIORITY RISK FINDINGS

Campaign	Credential Rate	Modelled Financial Exposure	Risk Rating	Priority
A – HR Bonus Notification	18%	$391.50M	Medium-High	2
B – IT System Password Reset	30%	$652.50M	Critical	1
C – CEO Urgent Document Review	15%	$326.25M	High	3

Campaign B – Critical Risk

The IT password-reset simulation recorded 75 credential submissions from 250 recipients. This suggests that employees may be susceptible to fraudulent messages impersonating legitimate IT support and password-management processes. The organisation should prioritise MFA, password-reset security improvements and targeted employee awareness training.

Campaign A – Medium-High Risk

The HR bonus notification recorded an 18% credential-submission rate. Employees may be vulnerable to messages exploiting their interest in compensation and employee benefits. Targeted HR awareness training and stronger verification procedures are recommended.

Campaign C – High Risk

The CEO document-review simulation recorded a 15% credential-submission rate and a 10% additional data-entry rate. Given the target population of executives and assistants, management should review privileged access, sensitive information handling and document-sharing verification procedures.

4. FINANCIAL RISK IMPLICATIONS

The Campaign B projection produces a modelled exposure of $652.5 million using the supplied breach cost and conditional probability.

This demonstrates the potential financial significance of successful credential-based attacks under the lab's assumptions. However, 150 expected breach-equivalent outcomes should not automatically be interpreted as 150 separate annual data breaches.

Management should validate the annual occurrence frequency and the relationship between compromised accounts and actual financial loss before adopting the estimate as an annual forecast.

---

5. PROPOSED SECURITY CONTROL INVESTMENTS

The assessment evaluated three security controls independently against the Campaign B modelled financial exposure.

Security Control	Implementation Cost	Risk-Reduction Benefit	ROI	Priority
Multi-Factor Authentication (MFA)	$90,000	$651.85M	**724,175%**	1

Security Awareness Training	$100,000	$391.50M	**391,400%**	2
Email Filtering	$50,000	$130.50M	**260,900%**	3

MFA provides the highest modelled risk-reduction benefit and stand-alone ROI under the supplied assumptions. Security awareness training addresses employee susceptibility, while email filtering adds a preventive layer by reducing exposure to malicious messages.

The control benefits are calculated independently against the same baseline and should not be added together without accounting for overlapping risk-reduction effects.

6. PROPOSED SECURITY INVESTMENT PORTFOLIO

The proposed security programme requires a total investment of **$490,000**, distributed across six initiatives.

Security Initiative	Proposed Investment
Enterprise MFA implementation	$90,000
Targeted phishing simulation programme	$25,000
Emergency security awareness training	$100,000
Advanced email security gateway	$50,000
Continuous security monitoring	$150,000
Security behaviour analytics	$75,000
TOTAL INVESTMENT	**$490,000**

Target Financial Outcomes

Using the proposed 90% portfolio risk-reduction target, the following financial scenario is obtained:

Financial Metric	Projected Value
Current modelled exposure	$652,500,000
Target risk reduction (90%)	$587,250,000

Residual modelled exposure	$65,250,000
Total proposed investment	$490,000
Indicative net financial benefit	$586,760,000
Indicative portfolio ROI	**119,746.94%**

The 90% reduction is a proposed management target, not a measured outcome. Actual effectiveness must be established through security control testing and subsequent phishing simulations.

7. STRATEGIC RECOMMENDATIONS

The GRC Risk Analysis Team recommends a phased approach to strengthening GlobalTech's cybersecurity posture.

Immediate Actions – First 90 Days

1. **Implement enterprise MFA:** Prioritise privileged, finance, HR and other high-risk accounts before extending coverage across the organisation.
2. **Strengthen password-reset procedures:** Introduce stronger identity verification and monitoring to reduce account takeover risks.
3. **Conduct targeted security awareness training:** Focus on password-reset, HR and executive impersonation scenarios.
4. **Improve email security:** Strengthen malicious URL detection, attachment scanning and impersonation protection.
5. **Establish phishing reporting procedures:** Provide employees with an accessible reporting channel and ensure consistent incident triage.

Strategic Initiatives – Next 6 to 12 Months

1. Conduct quarterly phishing simulations and monitor changes in employee susceptibility.
2. Monitor MFA coverage and document implementation exceptions.
3. Introduce continuous security monitoring and security behaviour analytics with measurable objectives.
4. Track credential submissions, repeat susceptibility, phishing reporting rates and confirmed security incidents.
5. Regularly review the financial risk model using validated organisational incident and loss data.

8. MANAGEMENT DECISIONS REQUIRED

The Board, CISO and CFO are requested to consider the following actions:

Management Decision	Expected Outcome
Approve the phased $490,000 security investment programme, subject to budget validation	Support structured security improvements
Prioritise MFA and password-reset security improvements	Reduce credential-based account compromise risk
Approve targeted awareness training and quarterly phishing simulations	Improve employee security behaviour
Require quarterly reporting on security KPIs	Improve governance and control oversight
Commission validation of financial exposure assumptions	Strengthen the accuracy of risk-based budget decisions

9. CONCLUSION AND EXECUTIVE RECOMMENDATION

The phishing simulation results demonstrate that employee susceptibility remains an important cybersecurity risk for GlobalTech Inc. Campaign B presents the highest priority due to its 30% credential-submission rate and $652.5 million modelled financial exposure.

The proposed security investments provide an opportunity to strengthen identity protection, reduce human-related vulnerabilities and improve email security.

The GRC Risk Analysis Team recommends prioritising MFA implementation, targeted security awareness training and email protection, supported by continuous monitoring and regular risk reassessment.

Management should approve the proposed investments in stages, measure control effectiveness and validate the financial assumptions before treating the modelled exposure as an annual loss forecast.

PREPARED BY: Lead GRC Analyst
REPORT: Lab 3 – Advanced GRC Phishing Simulation & Quantitative Risk Analysis
CLASSIFICATION: Internal – Training and Risk Assessment Exercise

Financial qualification: All exposure, ROI and portfolio benefit figures are illustrative model outputs based on the supplied training assumptions. They are not independently verified financial forecasts.